

Endurecimiento vía GPO en Active Directory

Guía paso a paso para crear las Directivas de Grupo (GPO) que corrigen, a nivel de dominio, los hallazgos del reporte de auditoría — **excluyendo RDP y Gestión de dispositivos/MDM** (WinRM, RPC/WMI de gestión, WSUS, Webmin, Cockpit, IPMI), tal como pediste.

0. Antes de empezar

- Necesitas ser **Domain Admin** (o tener delegados los permisos de GPO) y la consola **GPMC** (`gpmc.msc`, se instala con RSAT en un DC o en tu PC con las Herramientas de Administración Remota de Servidores).
 - **No apliques todo de una vez a las ~90 máquinas.** Crea una OU de prueba (`OU=Piloto-Hardening`), mueve 2-3 equipos representativos, aplica los GPO ahí primero, valida unos días, y recién después expande al resto por oleadas.
 - Cada tema se hace en un **GPO separado** (no uno gigante): así, si algo rompe algo, deshabilitás/desvinculás solo ese GPO puntual sin afectar el resto.
 - Los servicios **no-Windows** que aparecieron en el reporte (el router 172.16.68.1, o cualquier equipo Linux/appliance con OpenSSH, Apache, nginx, vsFTPd) **no reciben GPO** — Active Directory solo gestiona equipos Windows unidos al dominio. Esos hay que corregirlos manualmente o con su propia herramienta de gestión.
 - Al final de cada sección: enlazá (Link) el GPO a la OU correspondiente, corré `gpupdate /force` en el equipo de prueba, y confirmá con `gpresult /h resultado.html` o `rsop.msc` que la política se aplicó.
-

1. Crear la estructura de GPOs

- 1 Abrí **Group Policy Management** (`gpmc.msc`).
 - 2 Click derecho sobre el dominio o la OU de destino → **Create a GPO in this domain, and Link it here...**
 - 3 Nombrá cada GPO de forma descriptiva, por ejemplo: `SEC-01 Deshabilitar SMBv1`, `SEC-02 Firma SMB`, etc. (se usan más abajo con esos nombres de referencia).
 - 4 No lo enlaces todavía a producción — primero editalo y probalo en la OU piloto.
-

2. SEC-01 — Deshabilitar SMBv1

SMBv1 no tiene un ADMX nativo; se aplica por registro vía **Group Policy Preferences**.

- 1 Editá el GPO → **Computer Configuration** → **Preferences** → **Windows Settings** → **Registry** → click derecho → **New** → **Registry Item**.
- 2 Completá:
 - **Hive:** `HKEY_LOCAL_MACHINE`
 - **Key Path:** `SYSTEM\CurrentControlSet\Services\LanmanServer\Parameters`
 - **Value name:** `SMB1`

- **Value type:** `REG_DWORD`
 - **Value data:** `0`
- 1 Guardá. Esto deshabilita que el equipo **acepte/negocie** SMBv1 (es el método que Microsoft documenta para desactivarlo a escala vía GPO). Si además querés remover la característica opcional por completo (`Disable-WindowsOptionalFeature`), eso requiere reinicio y se hace mejor con un script de arranque (Sección 12) o tu herramienta de despliegue de software.
-

3. SEC-02 — Exigir firma SMB (cliente y servidor)

Esta sí es una configuración de seguridad nativa, sin registro manual.

- 1 **Computer Configuration** → **Policies** → **Windows Settings** → **Security Settings** → **Local Policies** → **Security Options**.
 - 2 Configurá en **Enabled**:
 - `Microsoft network client: Digitally sign communications (always)`
 - `Microsoft network server: Digitally sign communications (always)`
-

4. SEC-03 — Deshabilitar el servidor Telnet

Vía **Group Policy Preferences** → **Servicios** (afecta solo a los equipos que realmente tengan el servicio Telnet instalado; en el resto no hace nada).

- 1 **Computer Configuration** → **Preferences** → **Control Panel Settings** → **Services** → click derecho → **New** → **Service**.
- 2 Completá:
 - **Service name:** `TlntSvr`
 - **Startup:** `Disabled`
 - **Service action:** `Stop service`

- 1 Guardá.
-

5. SEC-04 — Deshabilitar protocolos SSL/TLS obsoletos y cifrados débiles

5.1 Deshabilitar SSLv2 / SSLv3 / TLS 1.0 / TLS 1.1 (registro SCHANNEL)

Son 4 protocolos × 2 lados (Cliente/Servidor) × 2 valores = 16 entradas de registro. La forma más rápida es usar el **Registry Wizard** de GPP contra un equipo ya configurado como referencia (o cargarlas a mano una vez):

- 1 En un equipo de referencia, configurá manualmente en el registro estas claves (podés pegar esto en un `.reg` y ejecutarlo una vez en ese equipo de referencia, **no** en producción):

```
[HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols
\SSL 2.0\Client]
"Enabled"=dword:00000000
"DisabledByDefault"=dword:00000001

[HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols
\SSL 2.0\Server]
"Enabled"=dword:00000000
"DisabledByDefault"=dword:00000001

[HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols
\SSL 3.0\Client]
"Enabled"=dword:00000000
"DisabledByDefault"=dword:00000001

[HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols
\SSL 3.0\Server]
"Enabled"=dword:00000000
"DisabledByDefault"=dword:00000001

[HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols
\TLS 1.0\Client]
"Enabled"=dword:00000000
"DisabledByDefault"=dword:00000001

[HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols
\TLS 1.0\Server]
"Enabled"=dword:00000000
"DisabledByDefault"=dword:00000001

[HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols
\TLS 1.1\Client]
"Enabled"=dword:00000000
"DisabledByDefault"=dword:00000001

[HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols
\TLS 1.1\Server]
"Enabled"=dword:00000000
"DisabledByDefault"=dword:00000001
```

- 1 En el GPO: **Computer Configuration** → **Preferences** → **Windows Settings** → **Registry** → click derecho → **New** → **Registry Wizard** → apuntá al equipo de referencia → seleccioná las 8 claves `SCHANNEL\Protocols\...` → **Finish**. Esto importa automáticamente las 16 entradas sin cargarlas una por una.
- 2 Requiere **reiniciar** el equipo para que el cambio de SCHANNEL surta efecto completo.

5.2 Deshabilitar cifrados débiles (RC4/DES/3DES/MD5/EXPORT/NULL)

Esto sí tiene ADMX nativo:

- 1 **Computer Configuration** → **Administrative Templates** → **Network** → **SSL Configuration Settings** → **SSL Cipher Suite Order** → **Enabled**.
- 2 En el cuadro de texto, pegá la lista de suites permitidas separadas por coma, dejando **afuera** cualquiera con RC4/DES/3DES/MD5/NULL. Un ejemplo de orden recomendado (TLS 1.2/1.3, con forward secrecy):

```
TLS_AES_256_GCM_SHA384,TLS_AES_128_GCM_SHA256,TLS_CHACHA20_POLY1305_SHA256,
TLS_ECDHE_ECDSA_WITH_AES_256_GCM_SHA384,TLS_ECDHE_ECDSA_WITH_AES_128_GCM_SHA256,
TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384,TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256
```

(Ajustá según la versión de Windows del equipo de referencia — copiá el orden vigente de `Get-TlsCipherSuite` en un equipo actualizado y quitá manualmente cualquier suite con las palabras débiles antes de pegarla acá.)

6. SEC-05 — Deshabilitar la cuenta "Invitado"

- 1 **Computer Configuration** → **Policies** → **Windows Settings** → **Security Settings** → **Local Policies** → **Security Options**.
 - 2 **Accounts: Guest account status** → **Disabled**.
-

7. SEC-06 — Mantener UAC activo

- 1 Mismo contenedor de **Security Options**.
 - 2 Confirmá/dejá en **Enabled**: **User Account Control: Run all administrators in Admin Approval Mode**
 - 3 No lo apagues en ningún equipo salvo excepción justificada y documentada (rompe la protección contra elevación silenciosa).
-

8. SEC-07 — Eliminar credenciales de auto-inicio de sesión (autologon)

- 1 **Computer Configuration** → **Preferences** → **Windows Settings** → **Registry**.
 - 2 Item 1 — Eliminar la contraseña en texto plano:
 - **Action:** **Delete**
 - **Hive:** **HKEY_LOCAL_MACHINE**
 - **Key Path:** **SOFTWARE\Microsoft\Windows NT\CurrentVersion\Winlogon**
 - **Value name:** **DefaultPassword**
 - 1 Item 2 — Desactivar el autologon:
 - **Action:** **Update**
 - Misma ruta, **Value name:** **AutoAdminLogon**, **Type:** **REG_SZ**, **Value data:** **0**
 - 1 En los equipos que no tengan autologon configurado, este GPO no hace nada (las claves simplemente no existen).
-

9. SEC-08 — Deshabilitar LLMNR

Nativo, un solo clic:

- 1 **Computer Configuration** → **Administrative Templates** → **Network** → **DNS Client** → **Turn off Multicast Name Resolution** → **Enabled**.
-

10. SEC-09 — Deshabilitar NetBIOS sobre TCP/IP

No tiene ADMX nativo. Se aplica con un script de inicio (startup script) vía GPO:

- 1 En el SYSVOL del GPO, agregá un script `Disable-NetBIOS.ps1` con:

```
Get-CimInstance Win32_NetworkAdapterConfiguration -Filter "IPEnabled=True" |  
    ForEach-Object { $_ | Invoke-CimMethod -MethodName SetTcpipNetbios -Arguments @{TcpipNetbiosOptions=2} }
```

- 1 En el GPO: **Computer Configuration** → **Policies** → **Windows Settings** → **Scripts (Startup/Shutdown)** → **Startup** → **PowerShell Scripts** → agregá el script.
 - 2 Alternativa complementaria si asignás IP por DHCP: en el servidor DHCP, configurá el **Option 001 "Microsoft Disable Netbios Option"** con valor `0x2` a nivel de scope — así los equipos nuevos ya nacen sin NetBIOS sin depender del GPO.
-

11. SEC-10 — Firewall: bloquear puertos de acceso remoto de terceros no autorizado (VNC/AnyDesk/TeamViewer/Telnet)

- 1 **Computer Configuration** → **Policies** → **Windows Settings** → **Security Settings** → **Windows Defender Firewall with Advanced Security** → **Inbound Rules** → click derecho → **New Rule**.
 - 2 Creá una regla de **Block** para **Puerto TCP** con estos valores (podés agruparlos en una sola regla con puertos separados por coma): `23` (Telnet), `5900,5901` (VNC), `5938` (TeamViewer), `7070,6568` (AnyDesk).
 - 3 **Importante:** esto bloquea el puerto localmente en cada equipo, pero **no desinstala** el software si ya está instalado, y muchas de estas herramientas también usan salida saliente por 443 (HTTPS) hacia servidores relay, que este bloqueo de puertos de entrada no cubre. Para evitar que se **instalen** herramientas no autorizadas, complementalo con **AppLocker** o **Software Restriction Policies** (**Computer Configuration** → **Policies** → **Windows Settings** → **Security Settings** → **Application Control Policies** → **AppLocker**), bloqueando los ejecutables conocidos de esos productos por editor/hash.
 - 4 Probá primero en la OU piloto: una regla de bloqueo mal alcanzada puede cortar una herramienta de soporte que sí es legítima en tu organización — confirmá con el equipo de soporte/mesa de ayuda antes de expandir.
-

12. SEC-11 — Windows Defender: proteger que la protección en tiempo real no se apague

- 1 **Computer Configuration** → **Administrative Templates** → **Windows Components** → **Microsoft Defender Antivirus** → **Real-time Protection** → **Turn off real-time protection** → **Disabled** (doble negación intencional: "deshabilitar la política que apaga la protección" = la protección se mantiene encendida y no se puede apagar localmente).
 - 2 Si en algún grupo de equipos usás un antivirus de terceros como principal, **excluí esa OU** de este GPO (Windows apaga Defender automáticamente cuando detecta otro AV activo; forzarlo puede generar conflictos).
-

13. SEC-12 — Mitigar fuerza bruta (política de bloqueo de cuentas)

Esta es la contramedida real para el hallazgo "riesgo de fuerza bruta" sobre los servicios expuestos (FTP, SSH, MySQL, PostgreSQL, MSSQL, VNC, SMB, etc. detectados en el escaneo):

- 1 **Computer Configuration** → **Policies** → **Windows Settings** → **Security Settings** → **Account Policies** → **Account Lockout Policy**:
 - **Account lockout threshold**: 5 intentos inválidos
 - **Account lockout duration**: 15 minutos (o más)
 - **Reset account lockout counter after**: 15 minutos
 - 1 Complementará con **Password Policy** (mismo contenedor, **Account Policies** → **Password Policy**): longitud mínima 12+, complejidad habilitada, historial de contraseñas.
 - 2 Nota: esto protege las cuentas de **Windows/Active Directory**. Los servicios no-Windows expuestos (FTP, MySQL, PostgreSQL, appliances) tienen su propia política de cuentas y **no** la recibe vía GPO — hay que configurarla en cada uno por separado.
-

14. SEC-13 — Actualizaciones automáticas (parches), sin entrar en WSUS/MDM

Para no invadir "gestión/MDM" (que excluye), esta sección se limita a activar Windows Update automático, no a desplegar infraestructura WSUS:

- 1 **Computer Configuration** → **Administrative Templates** → **Windows Components** → **Windows Update** → **Configure Automatic Updates** → **Enabled**, opción "4 - Auto download and schedule the install", con horario en horas de bajo uso (ej. 3:00 AM).
 - 2 Esto asegura que los equipos se parcheen solos aunque el usuario nunca lo haga manualmente, sin necesitar un servidor WSUS dedicado.
-

15. Enlazar, filtrar y probar cada GPO

Para cada GPO creado en las secciones anteriores:

- 1 Click derecho sobre el GPO en la consola → **Link an Existing GPO...** sobre la **OU=Piloto-Hardening** primero.
- 2 (Opcional) **Security Filtering**: si querés un piloto aún más acotado, quitá "Authenticated Users" y agregá un grupo de seguridad **GG-Piloto-Hardening** con los equipos de prueba.
- 3 En un equipo de la OU piloto: **gpupdate /force**, después reiniciá si el cambio lo requiere (SMBv1, UAC, TLS).
- 4 Verificá que se aplicó: **gpresult /h C:\temp\resultado.html** (abrilo y buscá el GPO en la lista de "Applied GPOs") o **rsop.msc**.
- 5 Confirmá que nada se rompió: accesos de red, impresión, aplicaciones internas, soporte remoto legítimo. Esperá unos días de uso normal.

- 6 Recién ahí, volvé al GPO → **Scope** → agregá el link a la OU de producción real (o movés los equipos a la OU correspondiente) y repetí por oleadas, no los ~90 equipos de una sola vez.
-

16. Resumen de lo que queda fuera de este documento (a pedido)

- **RDP** (NLA, restricción de acceso): no incluido.
- **MDM / Gestión remota**: WinRM, RPC/WMI de administración (135), WSUS como servidor dedicado, Webmin, Cockpit, IPMI — no incluido.
- Servicios en equipos **no Windows** (el router del reporte, appliances Linux): GPO no aplica: requieren su propio proceso de hardening/parches.